Auditoría de fincas, organizaciones y aislamiento global

Fecha: **2026-10-23**. Alcance confirmado por el usuario: instrucciones del `Agents.md` actual del disco. Se auditó el árbol de trabajo, incluidas las remediaciones existentes de otros módulos. Este documento no declara remediados los hallazgos nuevos.

1. Resumen ejecutivo

El módulo requiere correcciones antes de aprobar su aislamiento por finca. La autenticación verifica la finca activa y el plugin filtra las consultas ordinarias, pero eso no basta para autorizar un ID de finca recibido en la URL. Se reprodujo un **P0: un administrador limitado a A1 puede modificar A2** manteniendo A1 en el encabezado. La misma operación sobre B1 devuelve 404: el aislamiento entre organizaciones sí se conserva en ese caso.

Se registran **12 hallazgos: 1 P0, 9 P1 y 2 P2**. Los P1 afectan el contrato de escritura del plugin, exactitud financiera, cortes históricos, fechas de traslado, disponibilidad de cierres, transición de planes y caché al cambiar de finca. Los P2 corresponden al trabajo repetido del consolidado y al contrato de entrega pública de imágenes R2, cuya exposición real no se verificó contra un bucket.

Premium tiene capacidades implementadas: consolidación, exportación, metas, cierres y correos personalizados. Sus sumas y ponderaciones pasan las pruebas; su interpretación histórica tiene defectos. Conviene corregirlos antes de presentar los cierres como evidencia histórica fiable.

Evidencia y alcance de las pruebas

Verificación	Resultado	Límite de la evidencia
Suite existente backend, `npm.cmd test`	**331/331**	Suite del árbol actual; no certifica una base desplegada
Reproducción específica de esta auditoría	**36 comprobaciones**	Aserciones de controles y de defectos presentes; verde no significa remediado
Matriz HTTP	**648 casos**, 27 módulos; **378 rechazos de finca** correctos	Rutas, autenticación y permisos reales; controladores de negocio sustituidos en esta matriz
F10, edición no autorizada	HTTP 200 en A2; 404 en B1	Ruta, controlador, servicio y hooks reales; colección Mongo adaptada en memoria
Concurrencia de contexto	100 tareas ALS + 60 peticiones HTTP, sin mezcla	Proceso Node local
Concurrencia de cupos	Una alta admitida; la otra rechazada. Igual al competir alta/reactivación	Servicio real, operación atómica del almacén simulada; falta replica set real
Frontend offline, `npm.cmd run test:tareas`	**4/4**	Más reproducción específica F08 con funciones reales en VM
Carga de consolidado	10 fincas / 10.000 animales, cinco mediciones de servicio y cinco HTTP	Persistencia en memoria, sin latencia ni planes de ejecución Mongo
Inventario transversal	**65 modelos; 300 sitios**	Barrido estático, incluidos sitios informativos y aliases; no prueba ausencia de código dinámico

No se cargaron archivos `.env`, no se conectó MongoDB ni se enviaron correos o solicitudes a sistemas de clientes. No se ejecutaron migraciones, compilaciones o despliegues. La suite nueva no modifica código de aplicación; genera evidencia local.

Archivos entregados:

- Reproducción automatizada.
- Resultados estructurados, incluida la matriz completa.
- Inventario completo de excepciones y generador.
- Salida de reproducciones, suite backend y suite frontend.

Reproducción desde la raíz, sin configurar una base:

```
Set-Location backend
node documentation/auditoria-fincas-organizaciones.repro.cjs
node documentation/auditoria-fincas-organizaciones.inventario.cjs
npm.cmd test
Set-Location ../frontend
npm.cmd run test:tareas
```

2. Mecanismo de aislamiento

`middleware/auth.js` relee usuario, membresía y organización. `accesoFinca-service` toma `X-Finca-Id`, o la finca principal cuando falta el encabezado, y comprueba membresía, organización y estado activo. Después `context/organizacion-context.js` establece `AsyncLocalStorage` con organización y finca. El plugin `models/plugins/organizacion-plugin.js` consulta ese contexto al ejecutar las operaciones Mongoose.

La organización se impone sobre un filtro recibido. La finca se impone únicamente en modelos declarados con `finca: true`, cuando existe finca en ALS y no se usa `omitirAislamientoFinca`. Un contexto de organización sin finca permite leer todas sus fincas: es útil para jobs y consolidación, pero no representa por sí mismo la autorización de un usuario.

Operación	¿Aislada?	Evidencia
`find`	Sí, org + finca según modelo/contexto	C01
`findOne`	Sí	C01
`findById`	Sí, a través de `findOne`; ID ajeno no supera el filtro	C01
`countDocuments`	Sí	C01
`distinct`	Sí	C01
`aggregate`	Raíz sí; relaciones no automáticamente	C02: `$match` inicial; después de `$geoNear` si existe
`$lookup`	**No** filtra la colección relacionada	C02; caso real en `reporte-controller.js:2242`
`updateOne`	Filtra documento de origen, **no impide cambiar org/finca en `$set`**	C01/F01
`updateMany`	Filtra documentos de origen; misma limitación del contenido actualizado	C01 + inspección del hook común
`findOneAndUpdate`	Filtra origen; no es autorización de referencias o de destino	C01/F10

Operación	¿Aislada?	Evidencia
`deleteOne`	Sí para filtro de origen	C01; no se ensaya borrado real Mongo
`deleteMany`	Sí para filtro de origen	C01
`insertMany`	Sobrescribe organización con ALS; **conserva finca explícita ajena**	F01
`bulkWrite`	**No** pasa por los hooks de consulta examinados	F01 modifica documento B desde contexto A en el adaptador
`save` / creación de documento	Solo rellena IDs ausentes; **acepta tenant explícito ajeno**	F01
`populate` de modelo con plugin	La consulta del modelo destino conserva su aislamiento	C03: referencia a Probe de B devuelve `null`
`populate` de `Usuario` global	**No** verifica membresía del usuario referenciado	C03: referencia preinsertada a AdminB devuelve su correo
`Model.collection.*` / driver nativo	**No** tiene aislamiento Mongoose	F01; inventario de scripts
`replaceOne`, `findOneAndReplace`, `findOneAndDelete`	Incluidos en la lista del hook	Inspección; no se añaden a los diez casos C01 ejecutados

Sin contexto: los modelos con organización obligatoria filtran por el ObjectId cero. No devuelven todos los tenants, aunque tampoco lanzan un error de contexto. `Auditoria`, con organización opcional, puede consultar globalmente sin ALS; los modelos globales como Usuario y Membresia tampoco reciben estos filtros. Crear documentos con tenant explícito sigue siendo posible fuera de ALS para aprovisionamiento y scripts.

Concurrencia: C05 ejecutó 100 contextos A/B entrelazados con consultas reales de Mongoose sobre el adaptador; C09 ejecutó 60 solicitudes HTTP intercaladas con JWT y finca distintos. No se mezclaron IDs. Al terminar, no quedó organización en el contexto exterior.

Índices: C13 confirma los índices declarados de Animal `(org, finca, identificadorFinca)`, Animal `(org, diio)`, Finca `(org, codigo)`, Potrero y Lote `(org, finca, codigo)`, y Camada `(org, finca, codigoCamada)`. `diio` tiene índice parcial. Los identificadores globales deliberados incluyen correo, slug de organización, IDs de facturación y claves de coordinación. No se inspeccionaron índices físicos de producción: una migración pendiente podría diferir del esquema.

Referencias: `ref` de Mongoose no es una clave foránea con validación de tenant. Los servicios validan referencias concretas mediante consultas aisladas y helpers como `validarUsuarioAsignable`, pero no existe un validador transversal para toda referencia. C03 parte de una referencia corrupta sembrada por la prueba; **no demuestra que un endpoint público permita crearla**. El `$lookup` sanitario debe reforzarse para tolerar legado/importaciones inconsistentes. Las referencias históricas de animales trasladados requieren una regla explícita para permitir historia de otra finca de la misma organización.

3. Inventario de excepciones al aislamiento

La **tabla completa de 300 sitios**, con las seis columnas solicitadas, forma parte de este informe en el anexo de excepciones. Incluye cada aparición encontrada de bypass, driver, bulk y lookup; consultas manuales sobre modelos globales/Finca; consultas de scripts; opciones compartidas; y el alcance de los 65 modelos. Se conserva también la asignación de aliases, aunque no sea una operación ejecutable. Las consultas ordinarias protegidas por plugin no se clasifican como excepción por omitir el tenant en el texto del caller.

Resumen de decisiones relevantes; las líneas y sitios individuales están en el anexo:

Archivo:línea / familia	Qué consulta	Motivo	Organización	Fincas autorizadas	Riesgo
`accesoFinca-service.js:21,52`	Fincas antes de ALS	Construir contexto	Explícita	Membresía + estado	Control correcto
`adminOrganizacion-controller.js:25`; `auditoria-controller.js:76`	Datos globales de plataforma	Superadministración	Global deliberado	No aplica	Mantener guard de plataforma
`finca-service.js:111`	Mutación por ID de finca	Modelo solo organizacional	Plugin	**No valida destino**	**F10 P0**
`alimentacion-service.js:38,42`	Semilla de alimentos vía bulk	Upsert masivo	Explícita	Finca ALS explícita	Correcto
`categoriaAnimal-service.js:81`	Recalcular categorías vía bulk	Job	Solo lectura inicial	No revalida al escribir	F01, fortalecer filtros del bulk
`potreroCobertura-service.js:29`	Catálogo técnico global	Semilla común	No aplica	No aplica	Deliberado
`animal-controller.js:368`	DIIO en todas las fincas	Unicidad por organización	Plugin	No requiere ficha de otra finca	Correcto para unicidad
`eventoAnimalController`, `pesaje-controller`, `pesaje-integridad-service`	Historia por animal	Mantener trazabilidad tras traslado	Plugin	Animal actual visible; historia por ID	No quitar filtro organizacional
`catalogoFinanciero-controller`	Usos de catálogo	Catálogo compartido	Plugin	Alcance org deliberado	Permiso de gestión obligatorio
`plan-service.js:217,226,232,254`	Consumo de cuota	Cuota de organización	Plugin	No aplica a cuota	Correcto con ALS
`poblacionHistorica-service.js:115,118`	Animales e historia org completa	Reconstrucción a fecha	Plugin	Filtrado histórico posterior	F09 trabajo repetido
`reporteMultiFinca-service`, `consolidacionMultiFinca-controller`	Agregados multi-finca	Reportes autorizados	Plugin	Resolver + IDs	F03/F05/F09
`iatf-service`, `protocoloEngorde-service`, `protocoloPorcino-service`	Consolidación de protocolos	Multi-finca	Plugin	Lista del controlador; relacionados por ID	No usar lista vacía como autorización global
`reporte-controller.js:2242`	Join a `animals`	Indicador sanitario	Solo raíz	Referencia por ID	F01: falta guard en join
`archivoRoutes.js:23`	Archivo local de dron	Resolver pertenencia	Plugin	Permiso + membresía	Control presente

Archivo:línea / familia	Qué consulta	Motivo	Organización	Fincas autorizadas	Riesgo
Scripts de migración / normalización	Lectura y cambio global, a veces nativos	Operación de plataforma	Explícito, legado o global según script	No usuario final	Impacto operativo; no ejecutados
`diagnostico-u01`, `diagnostico-importaciones`, `verificarAislamientoSaas`	Diagnóstico global	Auditoría operativa	Alcance global deliberado	No aplica	No publicar resultados a tenants

Archivos y procesos: los archivos locales de dron pasan por autenticación, permiso y pertenencia; R2 devuelve una URL pública distinta de ese flujo (F11). Las claves R2 contienen organización/finca, pero el nombre de una ruta no es control de acceso. Exportaciones consolidadas usan el mismo resolver de fincas y validan acceso al cierre. Los crons enumeran organizaciones habilitadas y crean ALS por organización; los resúmenes y alertas operativas filtran fincas por destinatario. `EMAIL_TEST_TO` es una excepción operativa de destino, no debe quedar configurada hacia un tercero en producción. El helper de correo administrativo general no filtra finca: no debe reutilizarse para enviar datos de una finca a todos los administradores.

Los logs del coordinador resumen varias organizaciones en la consola del servidor; no son una lista de tenant. El panel de auditoría de plataforma es deliberadamente global. El acceso de un tenant a registros de Auditoria depende de mantener su contexto. No se observó una ruta de tenant que exponga los logs globales del programador.

4. Matriz de pruebas de aislamiento

Fixture base: **Org A: A1, A2, A3; Org B: B1**. AdminA accede a las tres fincas A, EncargadoA1 solo a A1, AdminB solo a B1. La prueba F10 añade una variación temporal de AdminA restringida a A1, sin alterar el escenario base de la matriz.

Usuario	A1	A2	A3	B1
AdminA	Supera guard de finca	Supera guard de finca	Supera guard de finca	403
EncargadoA1	Supera guard de finca	403	403	403
AdminB	403	403	403	Supera guard de finca

Esperado y obtenido coinciden en los **648 casos**. «Supera guard» no significa permiso de negocio: los roles pueden recibir 403 posteriormente. Las 378 combinaciones de finca no autorizada devuelven 403 y `FINCA_ACCESS_DENIED` o `FINCA_NOT_AVAILABLE`.

Módulos ensayados (cada uno: 24 casos)	Lectura + escritura representativa	Resultado de finca
Animales, lotes, camadas, pesajes, potreros, rotaciones	GET `/`, POST `/`	Conforme
Alimentación	GET/POST `/planes`	Conforme
Sanidad, plan sanitario, tratamientos	GET `/`, POST `/`	Conforme
Aplicaciones sanitarias	GET `/`, POST `/unica`	Conforme
Reproducción	GET `/`, POST `/`	Conforme
IATF	GET/POST `/campanas`	Conforme
Protocolos de engorde	GET/POST `/ciclos`	Conforme

Módulos ensayados (cada uno: 24 casos)	Lectura + escritura representativa	Resultado de finca
Protocolos porcinos	GET/POST `/bandas`	Conforme
Finanzas, ventas, compras	GET `/`, POST `/`	Conforme
Reportes	GET `/multi-finca`, POST `/multi-finca/cierres`	Conforme
Fincas, tareas	GET `/`, POST `/`	Conforme; F10 cubre otra ruta de mutación
Eventos de animal, eventos de camada	GET por entidad, POST `/`	Conforme
Usuarios	GET `/perfil`, POST `/`	Conforme
Notificaciones	GET `/`, **PATCH** `/:id/leida`	Conforme; no existe POST equivalente
Importaciones	GET `/plantilla`, POST `/excel`	Conforme
Dron	GET `/`, POST `/procesar`	Conforme

La matriz monta el mismo guard central antes de los routers; sustituye handlers de negocio, límites de envío y guards de plan para aislar esta frontera. No acredita validaciones de cuerpos, transacciones, plan ni todos los endpoints de cada módulo. F10 ejecuta por separado la ruta de edición completa y demuestra por qué una matriz de encabezados correctos no basta. La matriz JSON conserva cada método, usuario, finca, resultado esperado, status y código.

5. Selección de finca, frontend y offline

Backend: la finca se valida de nuevo en cada solicitud. El token no permite ignorar la membresía vigente. C06 verifica rechazo de A2/B1 para EncargadoA1 y de A1 después de inactivarla. Los IDs de entidades de modelos con plugin se buscan dentro del contexto: `findById` ajeno no retorna el registro. Eso no cubre modelos organizacionales como Finca ni referencias globales.

Cambio visual: `App.js:293` usa una clave organización/finca para remontar `PlanProvider`, `AparienciaProvider` y la aplicación interna. Se reinician listas, formularios y estados internos de esos componentes. Preferencias globales guardadas en localStorage pueden sobrevivir; no constituyen por sí solas acceso a datos ajenos. No hay una cancelación central de las peticiones iniciadas antes del cambio.

F08: `api.js:28` toma la sesión al enviar, pero no compara contexto después de recibir. `Animales.js:395` guarda el inventario tras el `await`; `offlineStorage.js:190` calcula la clave de caché al guardar. La reproducción demora una respuesta de A1, cambia la sesión a A2 y comprueba que el animal A1 queda guardado bajo A2. El remount de React no cancela ese efecto externo. Se demostró contaminación de caché, no un render real en navegador ni un salto de organización por API.

Enlaces directos: la aplicación principal navega por estados de módulo; no se encontró una ruta universal de URL `/animales/:id` que permita inferir otro mecanismo de autorización. Para cualquier detalle solicitado a la API, la garantía es el filtro del backend, no esconder el enlace. C01 prueba un ID de otra organización con resultado no visible; F10 documenta la excepción del recurso Finca.

Offline: hay una base IndexedDB común, con particiones lógicas por organización/finca/usuario; no una base física independiente por finca. La cola usa esas claves. `offlineSync` vuelve a comprobar contexto antes de enviar y las tareas añaden `contextoEsperado`; la suite frontend confirma que una operación de la sesión anterior no se envía tras cambiar de finca. La rama de notas debe conservar esa comprobación al evolucionar. El backend vuelve a autenticar los envíos offline, y una membresía/finca revocada no pasa la autorización. F08 afecta las lecturas guardadas y requiere su propia corrección aunque las cuatro pruebas de la cola pasen.

6. Administración de organizaciones y fincas

Área	Comportamiento observado	Evaluación
Alta de organización	Aprovisionamiento de plataforma en transacción: organización, finca principal, administrador/invitación y catálogos	Conservar transacción y consentimiento de cuentas existentes
Edición general	Datos de nombre, razón social, país y zona horaria en modelo/aprovisionamiento; no CRUD completo de organización en rutas de plataforma	Capacidad administrativa parcial
Zona horaria	Texto con default Costa Rica; no validador IANA universal al aprovisionar	Endurecimiento: validar antes de persistir; consolidado mezcla zona civil/UTC (F04)
Moneda/fiscal	Movimientos CRC/USD; razón social; no campo explícito de moneda predeterminada organizacional ni expediente fiscal completo	Brecha de producto; no inferir datos dentro de `configuracion` libre
Organización suspendida/inactiva	`auth` bloquea acceso al tenant, incluida lectura	No es modo de solo lectura
Suscripción cancelada/suspendida	Organización puede seguir Activa; guards de plan bloquean funcionalidades/escrituras que los usan	No todas las rutas tienen guard uniforme; p. ej. edición de nombre de finca no lo requiere. Definir política comercial explícita
Propiedad	No hay entidad `propietario` ni flujo dedicado de transferencia; se administran membresías y roles	Cambiar finca principal no transfiere propiedad de cuenta/empresa
Plan inferior	Cambia código del plan, conserva fincas activas y datos, bloquea nuevas altas al superar límite	**F07**, falta selección de fincas y transición controlada
Panel plataforma	Lista organizaciones, crea y cambia estado; asigna plan inicial; facturación actualiza plan por eventos	Acciones de creación/estado preparan datos para auditoría; no es un CRUD indiscriminado de registros de cliente
Fincas: crear/reactivar	Comprobación inicial y reserva por organización/recurso; relectura de consumo bajo reserva	C12: último cupo respetado con alta/alta y alta/reactivación
Fincas: especies	Líneas y objetivos normalizados; política Esencial validada	C13 rechaza Porcino cuando Esencial selecciona Bovino; líneas vacías no restringen por sí mismas, depende además del guard de plan
Fincas: ubicación	Texto `ubicacion`, sin coordenadas estructuradas	Calendario lunar usa fecha/zona organizacional; no consume esa ubicación ni simula coordenadas
Fincas: inactivación	No permite inactivar principal; controller impide inactivar finca activa; conserva documentos	Historia de animal trasladado sigue consultable; consolidado/cierres de finca inactiva fallan por F05
Fincas: eliminación	No hay ruta DELETE de finca	Última finca no se elimina por API; no confundir inexistencia de ruta con validador universal de integridad

Área	Comportamiento observado	Evaluación
Permisos de gestión	`usuarios.gestionar` en crear/editar/estado/principal/líneas; lista basada en membresía	**F10**: falta aplicar lista de fincas al ID objetivo de mutaciones

Downgrade reproducido: Org A ampliada a seis fincas activas, plan cambiado a Pro (máximo cinco). `puedeCrearFinca` deniega alta y señala `sobreLimite`; `listarFincasAccesibles` sigue devolviendo seis. No se elige ninguna para archivo ni se establece una finca excedente de solo lectura. No se destruyen datos, lo cual debe conservarse al corregir. El webhook de facturación cambia `plan.codigo` en `facturacion-service.js:97–100` sin gestionar esta transición. También se pierden los guards Premium de reportes/cierres al bajar: se necesita una política de consulta/exportación histórica.

Privacidad y salida de una organización: hay remediación de perfil individual y reportes exportables, pero no se identificó un flujo integral de exportación y eliminación/anonimización de todos los datos de una organización, archivos, retenciones y copias. Es una brecha de procedimiento/producto; no basta con borrar la cuenta del administrador. El artículo 7 de la Ley 8968 contempla derechos sobre datos personales, incluido acceso, rectificación y supresión; eso no equivale a exigir borrar indiscriminadamente toda la contabilidad o datos de terceros. Referencia oficial: Sistema Costarricense de Información Jurídica, Ley 8968. Esta revisión técnica no certifica cumplimiento jurídico.

7. Operaciones multi-finca

Traslado animal: el controlador deriva origen de la finca activa y resuelve destino entre fincas autorizadas. El servicio comprueba animales activos, identificadores en destino, especie/objetivo, y usa una transacción para registro de traslado, actualización del animal, cierre de pertenencia a lote, historia y eventos de salida/entrada. Conserva el `_id` del animal y referencias genealógicas/pesajes. Limpia lote/potrero actual. No crea un segundo animal ni reserva cupo adicional: es neutral al cupo organizacional. Validar rollback y conflictos de escritura con Mongo real sigue siendo un criterio de integración pendiente.

F06: la fecha se valida como fecha parseable, pero se acepta a futuro. La reproducción llama al servicio con fecha +30 días y observa el cambio inmediato de `Animal.fincaId`. La historia fechada dice que el traslado todavía no ocurrió; inventario actual y reconstrucción histórica discrepan. También debe definirse una política para fechas anteriores al nacimiento o a movimientos posteriores; estos casos no se acreditan como reproducidos en la prueba actual.

Transferencias financieras: crean egreso e ingreso con el mismo grupo, moneda, monto y sesión; `excluirConsolidacion` evita inflar ingreso/egreso externos. El comparativo conserva transferencias separadas. El esquema restringe moneda a CRC/USD. No se convierte automáticamente de una a otra.

Gastos compartidos: validan pertenencia de todas las fincas y crean las partidas en una transacción. El reparto habitual 100 entre tres produce 33,33 + 33,33 + 33,34. F02 muestra que no se exige precisión de centavos: total 1,001 con reparto MONTO de 1 se acepta y la suma difiere del total declarado. El caso de 0,01 repartido entre tres genera 0, 0 y 0,01; conserva total y el esquema permite cero, pero conviene evitar partidas vacías. No se etiqueta ese redondeo correcto como descuadre.

F12, reversión: los movimientos automáticos están protegidos de edición/borrado genérico. El mensaje pide modificarlos desde el origen, pero las rutas multi-finca solo listan/crean transferencias y gastos; no hay reversión del grupo. Conservar la protección y añadir contrapartidas/anulación transaccional e idempotente. No habilitar borrado independiente de una mitad.

Catálogo	Alcance real	Uso entre fincas
Razas / clasificaciones base	Configuración técnica común	Compartidas como vocabulario, no catálogo empresarial editable universal
Alimentos y raciones	Organización + finca	Se inicializan/crean por finca
Planes de alimentación	Organización + finca	Asignación local a lotes

Catálogo	Alcance real	Uso entre fincas
Planes sanitarios	Organización + finca	Locales; no biblioteca organizacional uniforme
Plantillas IATF	Modelo organizacional con reglas de servicio	Revisar alcance en servicio; no inferir exclusividad Premium por nombre de modelo
Plantillas engorde y reproducción porcina	Alcance finca/organización	Guard `reportesMultiFinca` para compartir a nivel organizacional
Catálogo financiero / configuración productiva	Organización	Compartido; permisos de gestión independientes
Pastos base	Global técnico	Compartido deliberadamente

8. Consolidación, indicadores y rendimiento

Se ensayó `construirComparativoMultiFinca` con tres fincas desiguales, seis animales, pesos 100/200/300 por finca y dos monedas. No se encontró fallo aritmético en los indicadores de su objeto `consolidado`.

Indicador consolidado	Invariante / resultado C10
`fincas`	Cantidad de fincas del detalle: 3
`animalesActivos`, `bovinos`, `porcinos`	Suma por finca; activos 6
`animalesConPeso`	Suma de animales con dato: 6
`pesoPromedio`	Suma de pesos / animales con peso = 1400 / 6 = **233,3333 kg**; sin peso devuelve `null`
`ingresos`, `egresos`, `balance`	Suma de cada finca en CRC; 600, 3, 597
`transferenciasInternas`	Suma de entradas financieras; evita contar dos veces entrada+salida
`gastosCompartidos`	Suma de partidas de fincas seleccionadas
`partos`, `destetes`	Suma; fixture 2 y 3
`aplicaciones`, `tratamientosActivos`	Suma; fixture 5 y 7
`traslados`	Suma de entradas de animales en fincas seleccionadas; fixture 2
`monedas.CRC` y `monedas.USD`	Por moneda: ingresos, egresos, balance, transferencias y gastos compartidos coinciden con sus detalles; USD 6 − 3 = 3
Participaciones inventario/ingresos/egresos	Suman 100 % con denominador no nulo, dentro de tolerancia numérica

Los campos financieros superiores representan **CRC**, no CRC+USD. `pesoTotal` se usa internamente y se elimina de la salida consolidada; `pesoDestetePromedio` existe por finca, no como promedio consolidado. `traslados`/`transferenciasInternas` cuentan entradas al conjunto seleccionado: si se escoge solo origen, una salida no incrementa ese contador. La interfaz debe comunicar esa definición; no se debe interpretar como todos los movimientos del subconjunto. Los consolidados especializados de IATF/engorde/porcinos tienen sus propias métricas y pruebas previas: se inspeccionó su filtro de alcance, pero C10 no revalida cada fórmula de esos tres módulos.

Alcance: el permiso `reportes.ver` no es exclusivo de Administrador; se combina con feature Premium y `resolverFincasParaReporte`. C07 concede a una membresía solo A1/A2, obtiene dos fincas y rechaza solicitar A3. La

ausencia de filtro no significa todas las fincas de la organización: significa todas las accesibles activas. Encargado puede quedar excluido por permiso de reportes, aunque tenga fincas asignadas.

Exactitud temporal: F03 usa `Animal.pesoActual` para un corte anterior y cuenta tratamientos con estado actual Activo sin condición temporal equivalente al corte. F04 agrupa meses financieros con `$year/$month` UTC, mientras el período parte de fechas civiles: `2026-10-01T02:00Z` corresponde al 30 de septiembre en Costa Rica, pero el agregado lo clasifica en octubre. Las sumas correctas no corrigen esa semántica.

Metas: hay metas por organización y finca, fechas y valores numéricos; se valida acceso a finca (C11). Los valores financieros siguen la convención CRC de los campos superiores; no hay meta independiente por moneda. La UI y exportación deben decirlo.

Cierres: existe clave estable por período/especie/conjunto de fincas e índice organizacional; C11 verifica independencia del orden. Se persiste snapshot `historico-v2`. F05 confirma controller 200 antes de inactivar A2 y 404 después, aunque AdminA conserva acceso a toda la organización: se confunden autorización y estado operativo. Regenerar reemplaza los datos del snapshot y marca usuario/fecha; no conserva todas las versiones de ese cierre. F03/F04 también afectan nuevas generaciones.

Rendimiento F09: Node **v24.16.0**, Windows x64, 10 fincas, 10.000 animales sintéticos, cinco repeticiones por modalidad. Lecturas/agregados adaptados en memoria; historia vacía y sin volumen financiero/sanitario adicional.

Modalidad	Mediciones ms	Mediana
Servicio real de consolidación	143,66; 127,80; 116,90; 120,63; 116,07	**120,63 ms**
HTTP loopback + servicio + JSON, sin auth	178,90; 145,54; 118,43; 117,21; 116,74	**118,43 ms**

Las muestras son independientes; el calentamiento explica que la mediana HTTP no sea mayor. El resultado reproducible más significativo es **100.000 filas de animales leídas por ejecución para 10.000 animales únicos**: cada finca vuelve a cargar la base histórica completa de la organización. Optimizar a una carga y partición por finca. Estos tiempos no acreditan latencia de producción, percentil 95, memoria máxima ni capacidad con muchos usuarios; faltan mediciones con Mongo real, historia y cardinalidad representativas.

9. Evaluación del valor Premium

Precios **predeterminados del repositorio**, no cotización verificada del despliegue: Pro **USD 20/mes**, Premium **USD 35/mes**; configurables por entorno. El incremento es USD 15. Análisis basado en `backend/config/planes.js`, rutas y servicios, sin comparación de mercado.

Diferencia frente a Pro	Guard/implementación real	Madurez
Reportes multi-finca	`requireFeature('reportesMultiFinca')` en reporte, exportación, detalle, metas y cierres	Funcional, con F03/F04/F05/F09
Consolidados IATF/engorde/porcinos	Mismo feature, más `reportes.ver` y filtro de fincas	Implementados; no equivalen a dashboard universal
Plantillas compartidas de engorde/porcinos	Servicios exigen `reportesMultiFinca` al compartir organización	Implementado; uso del mismo feature dificulta comunicar este valor
Configuración avanzada de correos	`configuracionEmailAvanzada` en rutas de configuración y job de resúmenes Premium	Implementada, con fincas autorizadas por destinatario; entrega externa no ensayada

Diferencia frente a Pro	Guard/implementación real	Madurez
Capacidad	10 vs 5 fincas; 50 vs 20 usuarios; 10.000 vs 5.000 animales activos	Guard/reservas existentes; transición inferior incompleta F07
Dron	`USO_INTENSIVO`, límite mensual numérico nulo vs 150 en Pro	Capacidad configurada; no prometer SLA o disponibilidad solo por este flag
Soporte prioritario	`caracteristicasComerciales.soportePrioritario`	Declaración comercial; no se encontró cola/SLA implementado por ese flag

No son exclusivos de Premium: operar entre fincas comienza en Gestión; Pro ya incluye analítica económica, auditoría avanzada, protocolos, fotos y correos operativos. Los traslados y transferencias no justifican por sí solos el salto Pro → Premium. Permisos por finca y catálogos financieros compartidos tampoco son una exclusividad Premium.

Frente a una empresa con varias fincas, hay tablero comparativo, finanzas separadas por moneda, exportables, metas y cierres. Faltan cierre histórico plenamente reproducible, reversión financiera, política de reducción de plan, biblioteca uniforme de alimentos/planes sanitarios y proceso integral de salida/exportación organizacional. La autorización F10 debe resolverse antes de confiar en administradores regionales limitados por finca.

`MiPlan` comunica reportes multi-finca y correo avanzado, pero no explica con igual precisión los cierres, las metas, las plantillas compartidas, sus restricciones por moneda ni el alcance del soporte. `Reportes` y `GestionConsolidacionPremium` ya exponen buena parte de esas capacidades; la brecha es de explicación y fiabilidad, no ausencia total de interfaz.

Conclusión comercial: para seis a diez fincas, la capacidad adicional aporta una razón concreta para contratar Premium. Para una empresa de hasta cinco fincas, el diferencial depende de consolidación histórica y correo personalizado. Hoy no aprobaría venderlo como un sistema de cierres históricos fiables sin corregir los P1; después de esas correcciones, USD 15 adicionales pueden justificarse por reducir preparación manual de comparativos y reportes. No se estima ahorro monetario ni aceptación del mercado sin medirlos.

10. Hallazgos y plan de acción priorizado

Cada ID corresponde a una comprobación del archivo de reproducción. Las aserciones de hallazgo verifican que el defecto existe; deben convertirse en pruebas de rechazo/comportamiento correcto durante la remediación. Los tiempos del benchmark pueden variar.

ID / prioridad	Descubrimiento y evidencia	Corrección propuesta / criterio de cierre
F10 — P0	Administrador restringido A1 lista una finca, pero PUT de A2 con header A1 devuelve 200 y cambia nombre. B1 devuelve 404. `finca-controller.js:40`, `finca-service.js:111`, modelo Finca org-only. **HTTP completo local**, persistencia adaptada.	Autorizar ID objetivo contra membresía en editar, estado, principal y líneas; comprobar también imágenes/acciones equivalentes. Repetir prueba: A2 403/404 sin cambios y A1 permitido. No basta comprobar encabezado.
F01 — P1	Contrato de escritura incompleto: save/insertMany conservan finca ajena; `$set` puede mover tenant; bulk/driver no filtran; lookup/Usuario global no validan referencia. `organizacion-plugin.js:26,61,90,108,118`; C02/C03/F01. No se demuestra explotación remota de esas primitivas.	Tenant inmutable en escrituras ordinarias, excepción explícita para traslado autorizado, wrappers de bulk, filtros en joins y validación de referencias. Pruebas con modelos reales: operaciones

ID / prioridad	Descubrimiento y evidencia	Corrección propuesta / criterio de cierre
		ordinarias rechazan org/finca ajena; traslado válido conserva historia.
F08 — P1	Respuesta tardía A1 acaba en caché de A2. `api.js:28`, `Animales.js:395`, `offlineStorage.js:190`. Funciones reales ejecutadas con fetch/almacenamiento controlados.	Capturar contexto al iniciar y verificar al recibir/guardar; cancelar solicitudes anteriores. Reproducción debe dejar caché A2 sin datos A1; añadir cambio de usuario/organización y navegador real.
F03 — P1	Peso y tratamientos de hoy aparecen en un corte pasado. `reporteMultiFinca-service.js:292,322`; F03 combina función histórica real e inspección de pipeline.	Último pesaje válido al corte y estado sanitario histórico explícito. Fixture con peso/tratamiento antes/después debe mantener invariable el corte anterior.
F04 — P1	Evolución mensual usa UTC y desplaza operación de septiembre a octubre en Costa Rica. `reporteMultiFinca-service.js:332`; F04 comprueba fecha civil y expresión de pipeline.	Usar zona de organización en agrupación y período; probar bordes de mes/año y otra zona. Validar también pipeline en Mongo real.
F05 — P1	Cierre pasa de 200 a 404 al inactivar una de sus fincas sin revocar acceso. `consolidacionMultiFinca-controller.js:202,213`; resolver excluye inactivas.	Separar autorización histórica y disponibilidad operativa. Usuario autorizado sigue viendo/exportando cierres de inactivas, usuario revocado no.
F06 — P1	Traslado fechado +30 días mueve animal inmediatamente. `consolidacionMultiFinca-service.js:20,75-180`; servicio real, sesión simulada.	Rechazar futuro o implementar traslado programado que no cambie inventario antes. Verificar cronología y rollback con replica set.
F07 — P1	Premium con 6 fincas baja a Pro: siguen 6 activas, sin elección ni solo lectura del excedente. `facturacion-service.js:97-100`, `plan-service.js:379`; F07.	Transición explícita y auditable, selección por administrador, conservación de datos e historia, política de edición/exportación. Nunca inactivar arbitrariamente por orden de consulta.
F02 — P1	Reparto MONTO acepta total 1,001 y suma 1. `consolidacionMultiFinca-service.js:28`; F02.	Importes en unidades menores enteras o decimal exacto; validar precisión, suma y modos. Probar centavos, repartos y ambos tipos de moneda; impedir total declarado diferente a partidas.
F12 — P1	Transferencias/gastos protegidos remiten al origen, pero el origen no permite revertir. `movimientoFinanciero-proteccion-service.js`, `routes/finanza.js`; prueba funcional de protección + inspección de rutas/exports.	Reversión del grupo transaccional, idempotente, autorizando todas las fincas, moneda y auditoría; prueba reversión simultánea y error intermedio.
F09 — P2	Diez consultas históricas completas leen 100.000 filas para 10.000 animales. `poblacionHistorica-service.js:110`, `reporteMultiFinca-service.js:279`; benchmark instrumentado.	Cargar historia una vez; indexar por animal/finca y medir Mongo/HTTP con carga representativa. Prueba debe reducir filas repetidas y mantener resultados.
F11 — P2, riesgo condicionado a	R2 genera URL permanente sin firma y cache pública anual. `almacenamientoR2-service.js:95-121`; SDK	Separar branding público de fotos/adjuntos privados. Para privados

ID / prioridad	Descubrimiento y evidencia	Corrección propuesta / criterio de cierre
privacidad del recurso	simulado, ningún bucket real consultado.	usar descarga autorizada/URL firmada corta y política de revocación/caché. Validar acceso anónimo en staging antes de afirmar exposición real.

Orden recomendado: **F10 primero**; después F01/F08 y exactitud histórica/financiera; luego transiciones de plan, reversión y mejoras de rendimiento/almacenamiento. Mantener relectura de membresía, guards de organización/finca, separación de monedas y reserva de cupo que sí pasaron.

Validación que aún necesita infraestructura de pruebas

Para aprobar una remediación quedan pruebas de integración sobre un **replica set desechable**: atomicidad real de cuotas y transferencias, rollback, pipelines de Mongo completos, índices físicos y planes de consulta. También navegador con IndexedDB/service worker reales para F08, descarga R2 privada en staging y carga con historia financiera/sanitaria representativa. Estas limitaciones están separadas de los defectos reproducidos; no se presentan como comprobaciones ya superadas ni autorizan acciones en producción.